



Red Team Operations

Practical Capstone

NAME	ID	GROUP
AYMAN AHMED SAEED	21129983	CAI4_ISS3_G1VULN
AMR ADEL SAYED	21046408	CAI4_ISS3_G1VULN
ABRAM NADY SHAFIQ TEAM LEADER	21124022	CAI4_ISS3_G1VULN
TARIQ HANI MUHAMMAD	21004279	CAI4_ISS3_G1VULN

Table of Contents

Objective	2
Methodology.....	4
1.1 Phase 1 — Reconnaissance.....	5
1.2 Phase 2 — Initial Access	5
1.3 Phase 3 — Privilege Escalation.....	6
1.4 Phase 4 — Lateral Movement	7
1.5 Phase 5 — Post-Exploitation	8
1.6 Out-Of-Scop.....	9
Summary.....	10
References.....	10

Objective

This project simulates a real-world red team engagement commissioned by the Government of Trimento against their national Reserve Bank (The Reserve) [1]. The engagement was conducted by TryHackMe as a cybersecurity consultancy, and this The team will replicate the full attack chain within the Red Team Capstone Challenge provided lab environment.

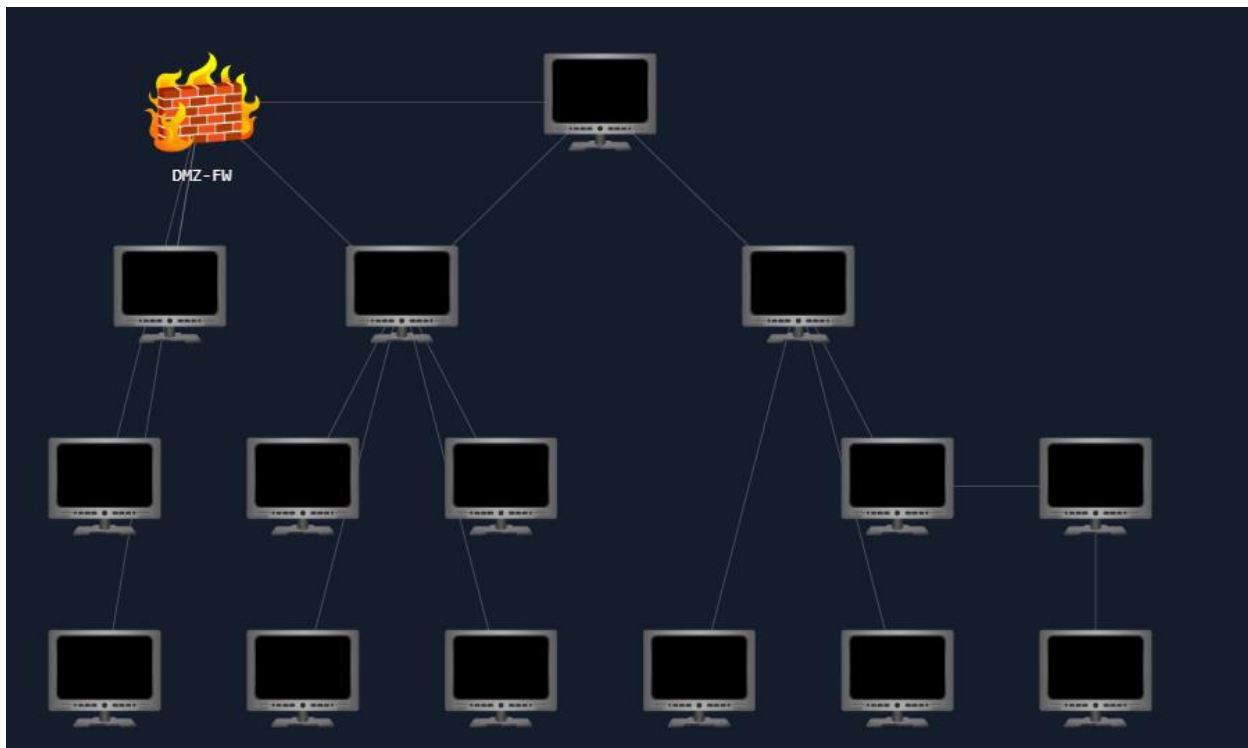
The Reserve operates two divisions: a Corporate division that handles foreign investments, and a Bank division that manages the core banking infrastructure connecting to banks worldwide [1]. The government's primary concern is that the corporate division may be endangering the core banking system due to insufficient network segregation [1].

The goal of this project, as defined by the lab [1][2], is to:

- Compromise the corporate division of TheReserve
- Pivot from the corporate network into the bank division
- Gain access to the SWIFT internal web application at <http://swift.bank.thereserve.loc/>
- Demonstrate a simulated fraudulent money transfer between two pre-created core banking accounts by fulfilling both the capturer and approver roles within the SWIFT transfer process [1]
- There are 20 flags to collect, spread across 10 different phases, with 6912 possible path combinations!

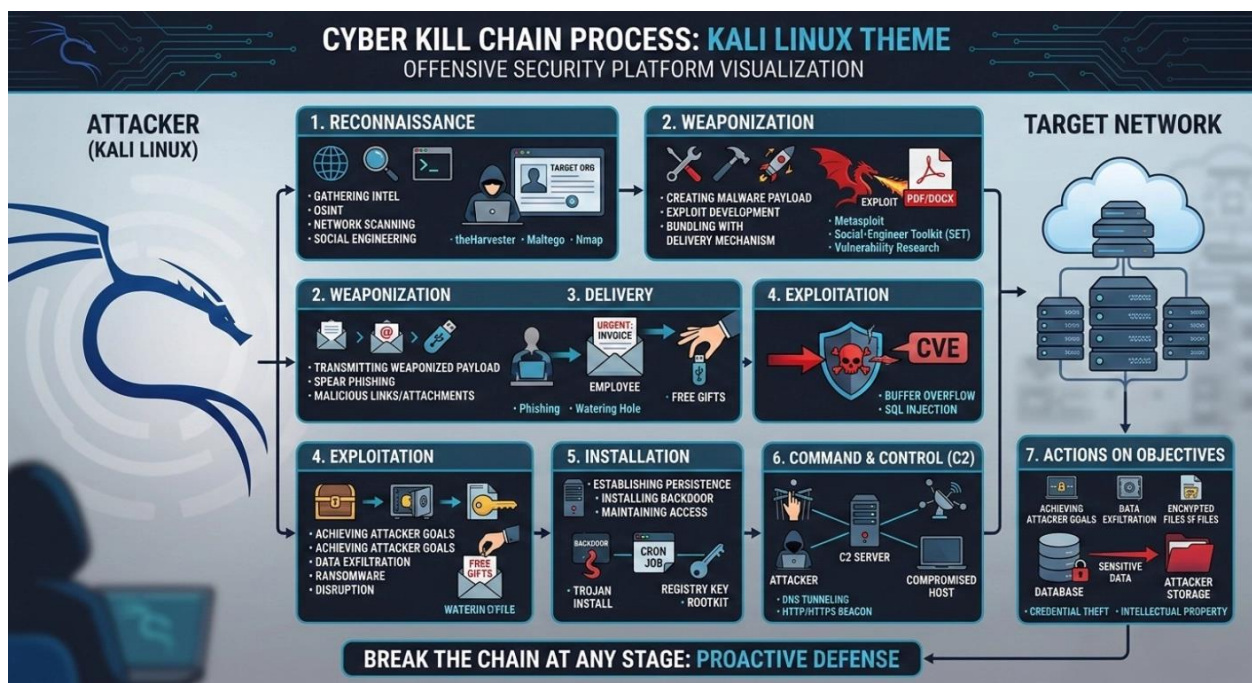
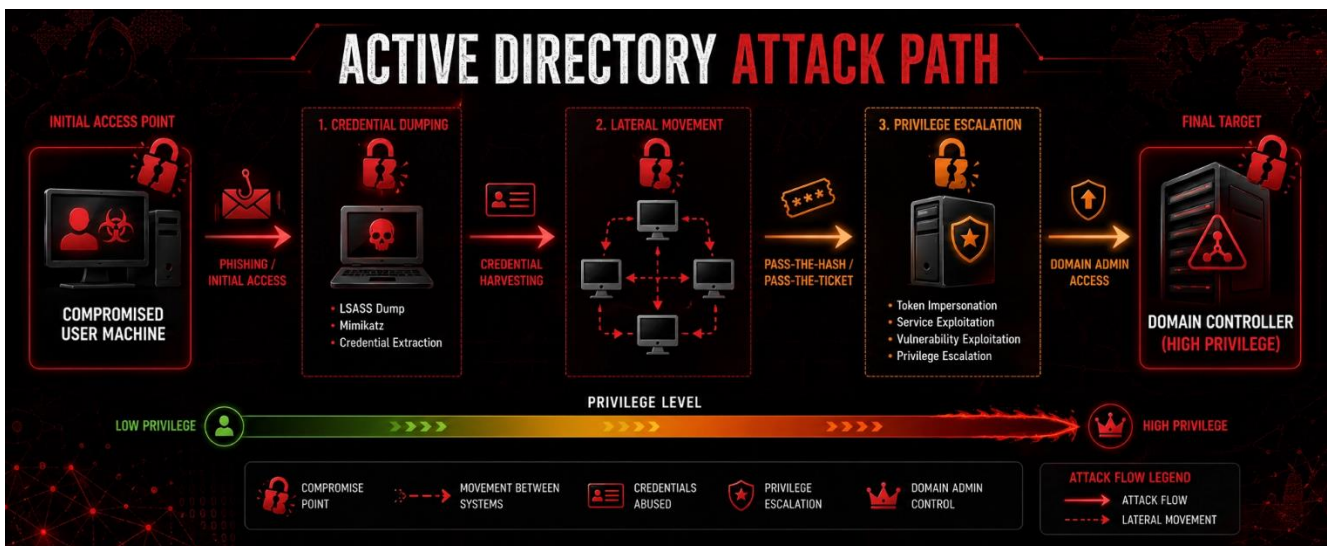
The project validates the following skills learned from the TryHackMe Red Team Learning Path [2]:

- Simulated OSINT
- Enumeration & Fuzzing
- Phishing
- AV Evasion
- Lateral Movement
- Active Directory Exploitation
- Linux and Windows Security Testing
- Privilege Escalation
- Post-Compromise Exploitation



Methodology

The team will follow the Cyber Kill Chain model as the structural framework for this engagement [2]. As stated in the challenge brief, "the challenge includes several phases structured around the cyber kill chain that will require you to enumerate a perimeter, Breach the organization, perform lateral movement, and finally perform Post Exploitation to show impact" — paraphrased from [2].

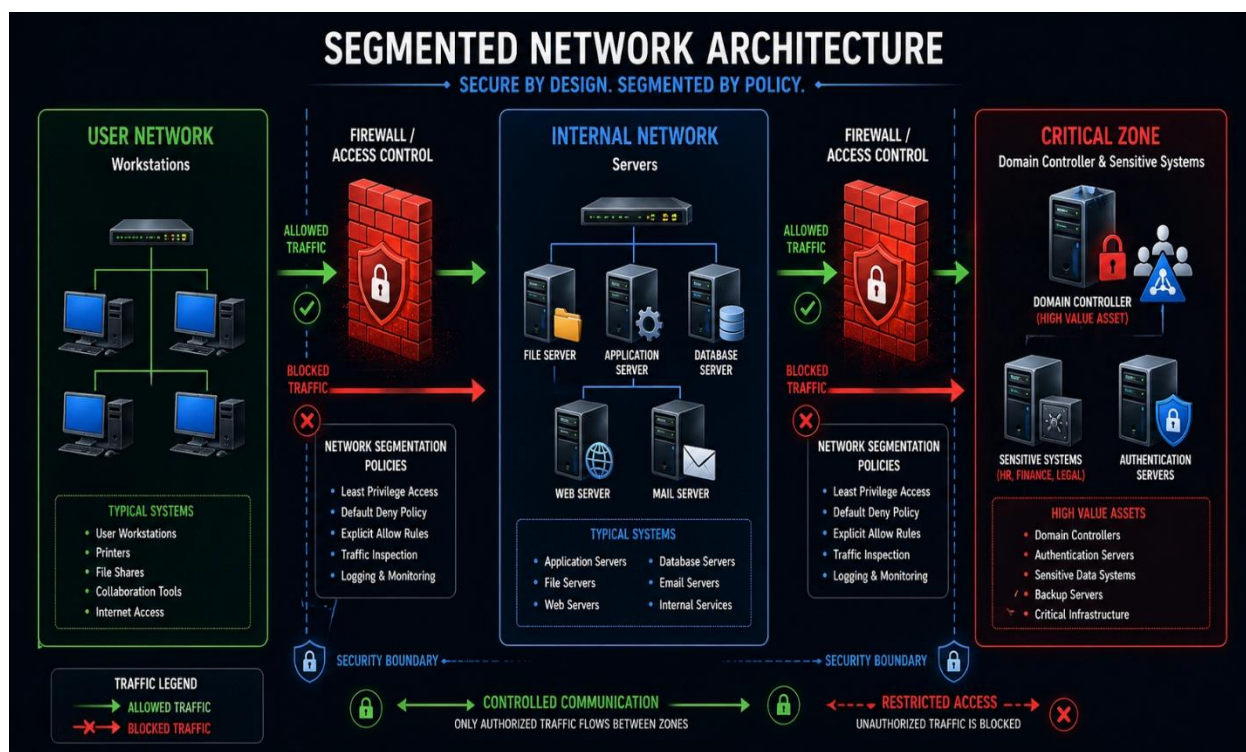


1.1 Phase 1 — Reconnaissance & OSINT

The team will begin by performing simulated OSINT against TheReserve's corporate website, which is exposed on the external network [1]. This includes identifying employees, email addresses, and any publicly available information that can support later phishing or exploitation.

Active enumeration will then be performed against all IP ranges accessible through The VPN connection to map the full attack surface [1].

Tools: nmap, gobuster, theHarvester

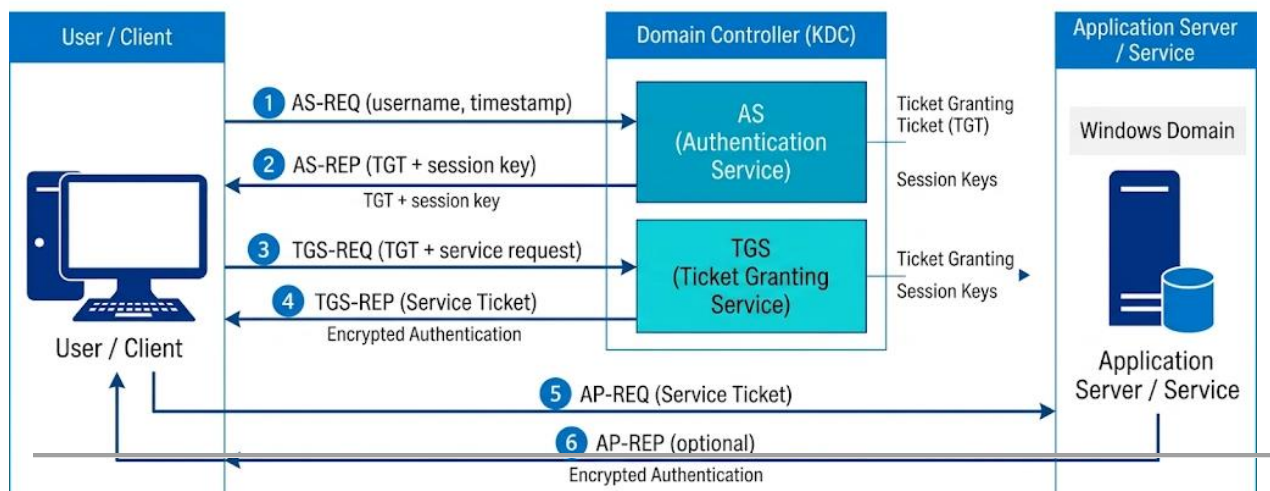


1.2 Phase 2 — Initial Access & Phishing

Based on gathered intelligence, the team will craft a phishing campaign targeting The Reserve employees [1]. This includes attacking employee mailboxes through the WebMail is a host to gain initial credentials or deliver a malicious payload [1]. AV

evasion techniques will be applied to bypass endpoint defenses, as required by the lab environment [2].

Tools: Burp Suite, GoPhish, custom payloads with AV evasion



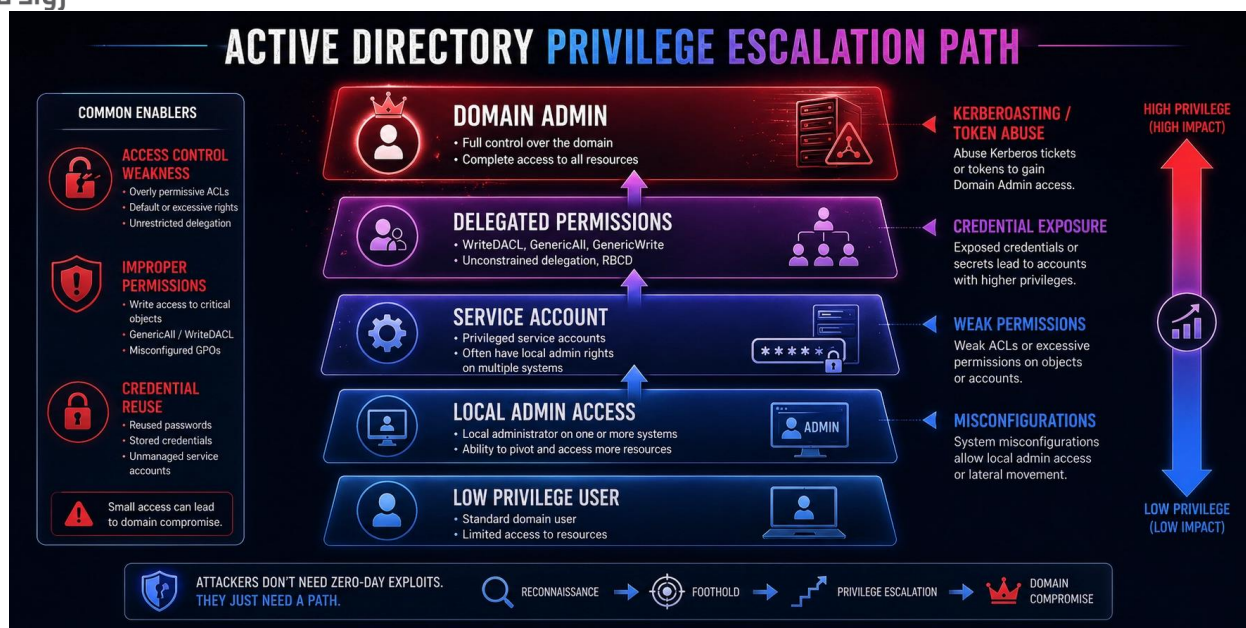
1.3 Phase 3 — Privilege Escalation

After gaining an initial foothold, the team will escalate privileges on the compromised host. Both Linux and Windows privilege escalation paths are expected based on the lab's mixed environment [2]. [1]

Techniques include:

- Abusing misconfigurations and weak permissions
- Exploiting vulnerable services
- Credential harvesting for reuse

Tools: LinPEAS, WinPEAS, Manuel



1.4 Phase 4 — Lateral Movement & Active Directory Exploitation

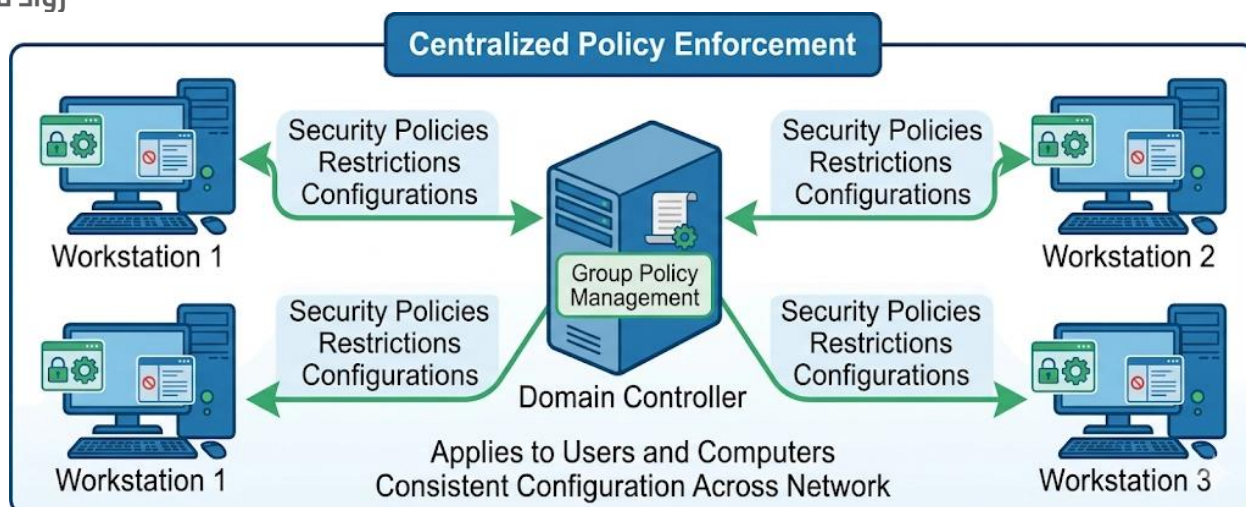
Once elevated access is obtained, the team will move laterally from the corporate network into the bank network, targeting the core banking infrastructure [1]. Active Directory exploitation will be used to abuse domain trust relationships and reach high-value targets [2].

This phase directly tests the government's concern about insufficient segregation between the two divisions [1].

Techniques include:

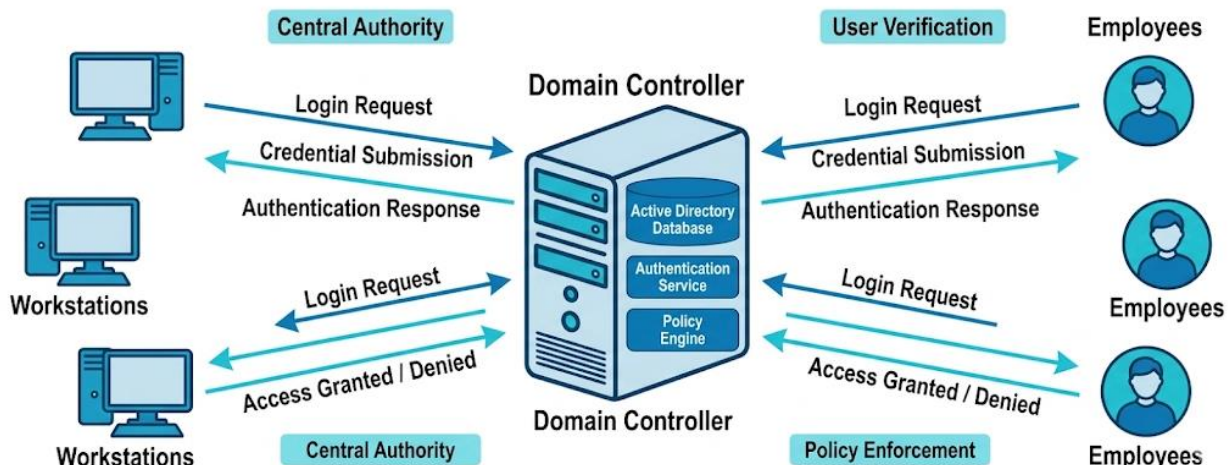
- Pass-the-Hash
- Kerberoasting
- Domain trust abuse

Tools: CrackMapExec, Impacket, BloodHound, Mimikatz



1.5 Phase 5 — Post-Exploitation (SWIFT Transfer)

- The final phase is Post Exploitation — the most critical step of the engagement. The team must access the SWIFT internal web application and perform a Simulated fraudulent money transfer between the two pre-created accounts [1].
- The SWIFT transfer process requires separation of duties — one employee captures the transfer and a different employee approves it [1]. Therefore the team must:
 - Obtain credentials for an employee with the capturer role
 - Obtain credentials for an employee with the approver role
 - Execute the approval from the designated jump host as required by the SWIFT process [1]
- This step fully demonstrates the impact of the corporate-to-bank compromise.



1.6 Out-Of-Scop

All activities are performed exclusively within the TryHackMe lab environment [1][2].
The following are strictly out of scope and will not be attempted:

- Security testing of the TryHackMe VPN or scoring servers [1]
- Attacking mailboxes of other red teamers [1]
- Any DoS attacks that render the network inoperable [1]
- External internet OSINT [1]

Summary

This project places the team in the role of a red team operator conducting a real-world-style engagement against a simulated national reserve bank. As described in the Challenge brief, "This network was created to simulate what you would typically find on a real client engagement during a red team", with vulnerabilities and misconfigurations drawn from real engagements — paraphrased from [2].

The engagement covers the full Cyber Kill Chain: from reconnaissance and phishing, through privilege escalation and lateral movement, to the final Post-Exploitation of a simulated fraudulent SWIFT transfer [1][2]. The core question being The question is whether the corporate division's compromise can lead to the compromise of the bank division, a real-world concern for any organization with insufficient internal network segregation [1].

References

[1] TryHackMe. Red Team Capstone Challenge — Project Brief (TheReserve / Trimento Engagement). TryHackMe Learning Platform. Available at:

<https://tryhackme.com/room/redteamcapstonechallenge>

[2] TryHackMe. Red Team Capstone Challenge — Welcome & Learning Objectives. TryHackMe Red Team Learning Path. Available at:

<https://tryhackme.com/paths/redteaming/>